Research.gov - Proposal Review Page

research.gov/gapps-web/gapps/viewApplicationReview

Agency Name:

National Science Foundation

Agency Tracking Number:

2533187

Organization:

Translational Impacts

NSF Program:

SafeOSE

PI/PD:

Millman, Kenneth

Application Title:

NSF Safe-OSE: Securing the Scientific Python Ecosystem

Rating:

Very Good

Review

Summary

Proposal Synopsis

The objective of this proposal is to improve security practices in the Scientific Python Open Source Ecosystem, SP-OSE, using SPEC (Scientific Python Ecosystem Coordination)

Intellectual Merit
Strengths
+ Community-backed approach is already established through SPEC, increasing chance of high impact

+ Unusual complexity of software ecosystem with multiple levels and many domain stacks

+ Steering of development through SPP (Scientific Python Project)

+ Clear novel contributions: Developer Reputation System and Federated Vulnerability Management System

+ Alignment with other standards (e.g., OpenSSF Open Source Software Security Mobilization Plan)

+ Clear mechanisms for evaluation: Security working group, process, and an external advisory board

+ PIs are exceptionally well qualified for understanding the SP-OSE

Weaknesses
- None of the PIs appear to be centrally interested in or have experience in security research

- The Automated Anomaly Detection portion is not adequately discussed or supported by the expertise of the PIs

- The following sentence on Page 14 lacks too much detail to be compelling “We will develop automated systems to analyze contribution patterns and flag anomalies in code submissions, prioritizing high-risk changes for expert scrutiny.”

Broader Impacts
Strengths
+ Impact on cutting-edge projects, including scientific collaborations

+ Part of many machine learning pipelines

+ Importance on education, due to relevance of Python, and specifically Berkley teaching stack that uses SP-OSE and is used by 50 universities

Weaknesses
- Impact limited to collaboration aspects but does not seem to be focused on impact in new security threats

Additional Solicitation-specific Review Criteria
Strengths & Weaknesses
Strengths:

+ Security landscape described in terms of three major groups of vulnerabilities, supply chain vulnerabilities, access control vulnerabilities, and insider attack vulnerabilities

+ Unusually robust community: 80 team members, almost 700 members on Discord server, third annual summit

+ Unusually well-established processes for quality control due to SPEC

+ Clear and achievable milestones

Weaknesses:

- It seems that the vulnerabilities were selected such that addressing them would be straightforward, but there does not seem to have been an effort to demonstrate that the three groups include the most important threats, or at least there is no evidence that other groups were considered

- The appropriateness of focus would be more compelling if there was someone on the team whose primary research interest is security

Summary Statement
The project is unusually complex and influential. Goals and milestones for the project are clearly stated. A robust community is in place to contribute and benefit from the outcomes. However, the lack of a security expert raises the concern if the most relevant threats have been captured.